

Relatório de Análise e Classificação de Risco de Segurança - Metodologia OWASP

Cenário: SQL Injection num formulário web de uma organização de saúde, permitindo a um utilizador autenticado executar interrogações arbitrárias na base de dados de dados pessoais.

Fatores de Probabilidade (Likelihood)

Fator	Valor	Justificação
Skill Level	5	SQL injection bem documentado, ferramentas automáticas disponíveis
Motive	9	Dados de saúde de milhares de utentes têm alto valor
Opportunity	7	Requer autenticação, mas qualquer paciente tem acesso
Size	5	Todos os utilizadores autenticados (potencialmente milhares)
Ease of Discovery	7	Campo de formulário visível a qualquer utilizador autenticado
Ease of Exploit	5	Requer conhecimento de SQL, mas existem ferramentas que automatizam
Awareness	6	SQL injection no OWASP Top 10 — ameaça amplamente conhecida
Intrusion Detection	3	Provável ausência de monitorização de queries anómalas

$$\text{Likelihood} = (5+9+7+5+7+5+6+3) / 8 = 5,9 \rightarrow \text{MEDIUM}$$

Fatores de Impacto

Fator	Valor	Justificação
Confidentiality	7	Dados pessoais de todos os utentes podem ser lidos
Integrity	1	Dados não podem ser alterados
Availability	1	Sem impacto na disponibilidade
Accountability	5	Atacante é utilizador autenticado — alguma rastreabilidade
Financial Damage	7	Multas RGPD até 4% do volume de negócios global
Reputation Damage	5	Violação de dados de saúde com impacto reputacional severo
Non-compliance	7	Violação direta do RGPD (dados pessoais e de saúde)
Privacy Violation	9	Exposição massiva de dados sensíveis de milhares de utentes

$$\text{Impacto Técnico} = (7+1+1+5)/4 = 3,5 \rightarrow \text{LOW} \mid \text{Impacto Negócio} = (7+5+7+9)/4 = 7,0 \rightarrow \text{HIGH}$$

Impacto final considerado (o maior): **HIGH**

Nível de Risco Final

$$\text{Likelihood MEDIUM} \times \text{Impact HIGH} = \text{Risco ALTO (HIGH)}$$

Mitigação

- Usar *prepared statements* / *parameterized queries* — elimina a vulnerabilidade na raiz
- Validar e sanitizar todos os inputs no servidor
- Aplicar princípio do menor privilégio à conta de base de dados (read-only onde aplicável)
- Implementar WAF com regras anti-SQLi
- Monitorizar queries anómalas e manter logs de auditoria
- Realizar testes de penetração e análise de código regulares (SAST/DAST)

Consequências sem mitigação

Coima até 20M€ ou 4% do volume de negócios global (RGPD Art. 83), processos de indemnização civis massivos por parte dos utentes afetados e perda de confiança dos mesmos, dano reputacional irreversível para a organização.